

Safeguard 6.8: Define and Maintain Role-Based Access Control

Asset Type: **Users**

Security Function: **Govern**

IG3

Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.

CONTROL 7

Continuous Vulnerability Management

Develop a plan to continuously assess and track vulnerabilities on all enterprise assets within the enterprise's infrastructure, in order to remediate, and minimize, the window of opportunity for attackers. Monitor public and private industry sources for new threat and vulnerability information.

Safeguard 7.1: Establish and Maintain a Vulnerability Management Process

Asset Type: **Documentation**

Security Function: **Govern**

IG1

IG2

IG3

Establish and maintain a documented vulnerability management process for enterprise assets. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 7.2: Establish and Maintain a Remediation Process

Asset Type: **Documentation**

Security Function: **Govern**

IG1

IG2

IG3

Establish and maintain a risk-based remediation strategy documented in a remediation process, with monthly, or more frequent, reviews.

Safeguard 7.3: Perform Automated Operating System Patch Management

Asset Type: **Software**

Security Function: **Protect**

IG1

IG2

IG3

Perform operating system updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.

Safeguard 7.4: Perform Automated Application Patch Management

Asset Type: Software	Security Function: Protect	IG1 IG2 IG3
-----------------------------	-----------------------------------	----------------------------------

Perform application updates on enterprise assets through automated patch management on a monthly, or more frequent, basis.

Safeguard 7.5: Perform Automated Vulnerability Scans of Internal Enterprise Assets

Asset Type: Software	Security Function: Identify	IG2 IG3
-----------------------------	------------------------------------	-----------------------

Perform automated vulnerability scans of internal enterprise assets on a quarterly, or more frequent, basis. Conduct both authenticated and unauthenticated scans.

Safeguard 7.6: Perform Automated Vulnerability Scans of Externally-Exposed Enterprise Assets

Asset Type: Software	Security Function: Identify	IG2 IG3
-----------------------------	------------------------------------	-----------------------

Perform automated vulnerability scans of externally-exposed enterprise assets. Perform scans on a monthly, or more frequent, basis.

Safeguard 7.7: Remediate Detected Vulnerabilities

Asset Type: Software	Security Function: Respond	IG2 IG3
-----------------------------	-----------------------------------	-----------------------

Remediate detected vulnerabilities in software through processes and tooling on a monthly, or more frequent, basis, based on the remediation process.

CONTROL 8

Audit Log Management

Collect, alert, review, and retain audit logs of events that could help detect, understand, or recover from an attack.

Safeguard 8.1: Establish and Maintain an Audit Log Management Process

Asset Type:	Documentation	Security Function:	Govern	IG1	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----	-----

Establish and maintain a documented audit log management process that defines the enterprise’s logging requirements. At a minimum, address the collection, review, and retention of audit logs for enterprise assets. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 8.2: Collect Audit Logs

Asset Type:	Data	Security Function:	Detect	IG1	IG2	IG3
-------------	------	--------------------	--------	-----	-----	-----

Collect audit logs. Ensure that logging, per the enterprise’s audit log management process, has been enabled across enterprise assets.

Safeguard 8.3: Ensure Adequate Audit Log Storage

Asset Type:	Data	Security Function:	Protect	IG1	IG2	IG3
-------------	------	--------------------	---------	-----	-----	-----

Ensure that logging destinations maintain adequate storage to comply with the enterprise’s audit log management process.

Safeguard 8.4: Standardize Time Synchronization

Asset Type:	Data	Security Function:	Protect	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Standardize time synchronization. Configure at least two synchronized time sources across enterprise assets, where supported.

Safeguard 8.5: Collect Detailed Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.

Safeguard 8.6: Collect DNS Query Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Collect DNS query audit logs on enterprise assets, where appropriate and supported.

Safeguard 8.7: Collect URL Request Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Collect URL request audit logs on enterprise assets, where appropriate and supported.

Safeguard 8.8: Collect Command-Line Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Collect command-line audit logs. Example implementations include collecting audit logs from PowerShell®, BASH™, and remote administrative terminals.

Safeguard 8.9: Centralize Audit Logs

Asset Type:	Data	Security Function:	Detect	IG2	IG3
-------------	------	--------------------	--------	-----	-----

Centralize, to the extent possible, audit log collection and retention across enterprise assets in accordance with the documented audit log management process. Example implementations primarily include leveraging a SIEM tool to centralize multiple log sources.

Safeguard 8.10: Retain Audit Logs

Asset Type:	Data	Security Function:	Protect	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Retain audit logs across enterprise assets for a minimum of 90 days.

Safeguard 8.11: Conduct Audit Log Reviews

Asset Type: Data	Security Function: Detect	IG2	IG3
------------------	---------------------------	-----	-----

Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.

Safeguard 8.12: Collect Service Provider Logs

Asset Type: Data	Security Function: Detect	IG3
------------------	---------------------------	-----

Collect service provider logs, where supported. Example implementations include collecting authentication and authorization events, data creation and disposal events, and user management events.

CONTROL 9

Email and Web Browser Protections

Improve protections and detections of threats from email and web vectors, as these are opportunities for attackers to manipulate human behavior through direct engagement.

Safeguard 9.1: Ensure Use of Only Fully Supported Browsers and Email Clients

Asset Type: Software	Security Function: Protect	IG1	IG2	IG3
----------------------	----------------------------	-----	-----	-----

Ensure only fully supported browsers and email clients are allowed to execute in the enterprise, only using the latest version of browsers and email clients provided through the vendor.

Safeguard 9.2: Use DNS Filtering Services

Asset Type: Devices	Security Function: Protect	IG1	IG2	IG3
---------------------	----------------------------	-----	-----	-----

Use DNS filtering services on all end-user devices, including remote and on-premises assets, to block access to known malicious domains.

Safeguard 9.3: Maintain and Enforce Network-Based URL Filters

Asset Type: **Network**

Security Function: **Protect**

IG2

IG3

Enforce and update network-based URL filters to limit an enterprise asset from connecting to potentially malicious or unapproved websites. Example implementations include category-based filtering, reputation-based filtering, or through the use of block lists. Enforce filters for all enterprise assets.

Safeguard 9.4: Restrict Unnecessary or Unauthorized Browser and Email Client Extensions

Asset Type: **Software**

Security Function: **Protect**

IG2

IG3

Restrict, either through uninstalling or disabling, any unauthorized or unnecessary browser or email client plugins, extensions, and add-on applications.

Safeguard 9.5: Implement DMARC

Asset Type: **Network**

Security Function: **Protect**

IG2

IG3

To lower the chance of spoofed or modified emails from valid domains, implement DMARC policy and verification, starting with implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail (DKIM) standards.

Safeguard 9.6: Block Unnecessary File Types

Asset Type: **Network**

Security Function: **Protect**

IG2

IG3

Block unnecessary file types attempting to enter the enterprise's email gateway.

Safeguard 9.7: Deploy and Maintain Email Server Anti-Malware Protections

Asset Type: **Network**

Security Function: **Protect**

IG3

Deploy and maintain email server anti-malware protections, such as attachment scanning and/or sandboxing.

CONTROL 10

Malware Defenses

Prevent or control the installation, spread, and execution of malicious applications, code, or scripts on enterprise assets.

Safeguard 10.1: Deploy and Maintain Anti-Malware Software

Asset Type:	Devices	Security Function:	Detect	IG1	IG2	IG3
-------------	---------	--------------------	--------	-----	-----	-----

Deploy and maintain anti-malware software on all enterprise assets.

Safeguard 10.2: Configure Automatic Anti-Malware Signature Updates

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Configure automatic updates for anti-malware signature files on all enterprise assets.

Safeguard 10.3: Disable Autorun and Autoplay for Removable Media

Asset Type:	Devices	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Disable autorun and autoplay auto-execute functionality for removable media.

Safeguard 10.4: Configure Automatic Anti-Malware Scanning of Removable Media

Asset Type:	Devices	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Configure anti-malware software to automatically scan removable media.

Safeguard 10.5: Enable Anti-Exploitation Features

Asset Type:	Devices	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Enable anti-exploitation features on enterprise assets and software, where possible, such as Microsoft® Data Execution Prevention (DEP), Windows® Defender Exploit Guard (WDEG), or Apple® System Integrity Protection (SIP) and Gatekeeper™.

Safeguard 10.6: Centrally Manage Anti-Malware Software

Asset Type:	Devices	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Centrally manage anti-malware software.

Safeguard 10.7: Use Behavior-Based Anti-Malware Software

Asset Type:	Devices	Security Function:	Detect	IG2	IG3
-------------	---------	--------------------	--------	-----	-----

Use behavior-based anti-malware software.

CONTROL 11

Data Recovery

Establish and maintain data recovery practices sufficient to restore in-scope enterprise assets to a pre-incident and trusted state.

Safeguard 11.1: Establish and Maintain a Data Recovery Process

Asset Type:	Documentation	Security Function:	Govern	IG1	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----	-----

Establish and maintain a documented data recovery process that includes detailed backup procedures. In the process, address the scope of data recovery activities, recovery prioritization, and the security of backup data. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 11.2: Perform Automated Backups

Asset Type:	Data	Security Function:	Recover	IG1	IG2	IG3
-------------	------	--------------------	---------	-----	-----	-----

Perform automated backups of in-scope enterprise assets. Run backups weekly, or more frequently, based on the sensitivity of the data.

Safeguard 11.3: Protect Recovery Data

Asset Type:	Data	Security Function:	Protect	IG1	IG2	IG3
-------------	------	--------------------	---------	-----	-----	-----

Protect recovery data with equivalent controls to the original data. Reference encryption or data separation, based on requirements.

Safeguard 11.4: Establish and Maintain an Isolated Instance of Recovery Data

Asset Type:	Data	Security Function:	Recover	IG1	IG2	IG3
-------------	------	--------------------	---------	-----	-----	-----

Establish and maintain an isolated instance of recovery data. Example implementations include, version controlling backup destinations through offline, cloud, or off-site systems or services.

Safeguard 11.5: Test Data Recovery

Asset Type:	Data	Security Function:	Recover	IG2	IG3
-------------	------	--------------------	---------	-----	-----

Test backup recovery quarterly, or more frequently, for a sampling of in-scope enterprise assets.

CONTROL 12

Network Infrastructure Management

Establish, implement, and actively manage (track, report, correct) network devices, in order to prevent attackers from exploiting vulnerable network services and access points.

Safeguard 12.1: Ensure Network Infrastructure is Up-to-Date

Asset Type:	Network	Security Function:	Protect	IG1	IG2	IG3
-------------	---------	--------------------	---------	-----	-----	-----

Ensure network infrastructure is kept up-to-date. Example implementations include running the latest stable release of software and/or using currently supported network as a service (NaaS) offerings. Review software versions monthly, or more frequently, to verify software support.

Safeguard 12.2: Establish and Maintain a Secure Network Architecture

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Design and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum. Example implementations may include documentation, policy, and design components.

Safeguard 12.3: Securely Manage Network Infrastructure

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Securely manage network infrastructure. Example implementations include version-controlled-infrastructure-as-code, and the use of secure network protocols, such as SSH and HTTPS.

Safeguard 12.4: Establish and Maintain Architecture Diagram(s)

Asset Type:	Documentation	Security Function:	Govern	IG2	IG3
-------------	---------------	--------------------	--------	-----	-----

Establish and maintain architecture diagram(s) and/or other network system documentation. Review and update documentation annually, or when significant enterprise changes occur that could impact this Safeguard.

Safeguard 12.5: Centralize Network Authentication, Authorization, and Auditing (AAA)

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Centralize network AAA.

Safeguard 12.6: Use of Secure Network Management and Communication Protocols

Asset Type:	Network	Security Function:	Protect	IG2	IG3
-------------	---------	--------------------	---------	-----	-----

Adopt secure network management protocols (e.g., 802.1X) and secure communication protocols (e.g., Wi-Fi Protected Access 2 (WPA2) Enterprise or more secure alternatives).